MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 059 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · AI & INCIDENT RESPONSE

AI Cyber Defense in a Small Enclave, Minute by Minute

What machine-speed defense can do for a small contractor's CUI enclave, where a human must decide, and the record an assessor and DoD will ask for after.

BY **PATRICK CARUSO** READING TIME · 7 MIN AI-AUTOMATION · INCIDENT-RESPONSE · DFARS · CMMC · AEGIS

The pitch for AI-driven security operations is that defense finally moves as fast as offense, and for the first fifteen minutes of an intrusion that is largely true. The trouble for a small defense contractor is everything after minute fifteen: the decisions a machine should not make, the actions it should not take on a server you cannot afford to lose, and the paper trail that DoD and a CMMC assessor will want long after the attacker is gone. The useful question is where, in a real incident, the machine should hold the pen.

Walk one. The setting is a forty-seat precision machining firm with a CUI enclave: one file server holding drawings, a few dozen workstations, a cloud identity provider, and a security stack that now includes an AI layer for triage and a response playbook that can disable accounts and isolate hosts. The firm has one IT lead, who is asleep.

The intrusion, minute by minute

02:14. An engineer's account signs in from an unfamiliar network using a valid session token, the kind of replay that follows a successful phishing page. Multifactor passed hours ago, on the engineer's real phone, when the token was minted. The identity provider raises a risky-sign-in alert. So does the endpoint agent, a moment later, for an unusual PowerShell launch. Within two minutes there are dozens of alerts across three consoles.

The machine acts, and should. This is where AI earns its keep. Correlating those alerts into one story (same account, same token, same hour, one host) is pattern work that a model does in seconds and a tired human does in half an hour. The output is a paragraph: probable token theft, active session, host named, files touched so far. Nobody has been woken up yet, and the work that would have taken the IT lead until 03:00 is already done.

02:17. The account begins enumerating the drawings share at a rate no engineer works at.

The machine acts, because someone said it could. The playbook revokes the account's sessions and disables it. That is a privileged function executed by a service account at two in the morning, and it is defensible for one reason only: a named person approved this class of action, for this kind of account, under these conditions, on an ordinary afternoon weeks earlier. The approval is a dated document with a version number, and the action log points to it.

Authorize at two in the afternoon what you want the machine to do at two in the morning, and write down who did.

02:19. The playbook's next step would isolate the source host. It also flags the file server, which the stolen session was reading from, for isolation.

The machine stops here. Isolating a workstation costs one engineer a morning. Isolating the only file server in a forty-seat shop stops production, and in a firm with no redundant server, that action has a business consequence a model cannot weigh. The playbook isolates the workstation, queues the server action, and pages the on-call phone.

FIELD COPY
ISSUE Nº 059
AI AUTOMATION

90 days

MINIMUM DFARS 252.204-7012 PRESERVATION OF AFFECTED IMAGES AND MONITORING DATA AFTER A REPORT - AN AUTO-REIMAGE CAN DESTROY IT

0 of 10

STEALTH-SCRAPER SESSIONS AEGIS'S BASELINE CLASSIFIER LABELED CORRECTLY IN MACTECH'S OWN RANGE RUN, PUBLISHED BY THE TEAM AS THE FINDING

5

SPRS POINTS CARRIED BY EACH OF 3.6.1 AND 3.6.2, THE INCIDENT HANDLING AND REPORTING REQUIREMENTS

◆ THE SCENARIO IS A COMPOSITE

The intrusion below is a simulation built for this piece, not a reconstruction of any real incident at MacTech or a client. The controls and clause duties it cites are real and current as of October 2026.

02:41. The IT lead acknowledges from bed, reads the summary, and opens the raw sign-in records the summary was built from. She keeps the server online, blocks the attacker's address range at the firewall, and starts a capture.

The human decides, with the machine's work in hand. Twenty-two minutes of latency sounds bad. The account was disabled at 02:17, so those twenty-two minutes cost almost nothing, which is the whole argument for letting the machine take the reversible step and leaving the expensive one to a person.

07:30. The engineer arrives, confirms he was not signing in at 02:14, and the question changes from containment to consequence. Did drawings leave the building? Is this a reportable cyber incident under DFARS 252.204-7012? When was it discovered, for the purposes of the 72-hour clock that Issue 11 walks hour by hour?

> **◆ A SUMMARY IS NOT EVIDENCE**
>
> A model's paragraph about an alert is a reading aid. The records it read are the evidence. Keep both, label which is which, and never let the summary replace the raw export in an incident file.

Only a human can answer. A model can assemble the evidence for each answer. Deciding that a contractor has discovered an incident affecting covered defense information is a judgment with contractual weight, and it belongs to a named person, not a classifier score.

09:00. The playbook's final stage, in many products, offers to reimage the affected workstation and return it to service.

Turn it off. DFARS 252.204-7012 requires the contractor to preserve images of affected systems and relevant monitoring data for at least 90 days from the report, and to give DoD access for forensic analysis on request. An automated clean-up that wipes the host has destroyed the evidence the clause requires you to keep. The most dangerous autonomous action in a CUI enclave is the tidy one.

Where the machine runs out

Three hard parts survive any amount of model improvement, and each is an operating decision rather than a product feature.

The first is blast radius. False positives are survivable when the action they trigger is cheap. Disabling a user account is cheap and reversible. Isolating a domain controller, a file server, or the one machine that runs the CMM software is neither, and small firms have more single points of failure than large ones, so the same false-positive rate costs them more. The practical rule is to grant autonomy by asset, not by alert type: workstations and user accounts yes, anything without a spare no.

The second is authority. NIST SP 800-171 requirement 3.1.7 wants privileged functions captured in audit logs, and 3.3.2 wants actions traceable to individual users. An automation account is not an individual. The chain an assessor will follow runs from the logged action to the playbook version in force to the person who approved it, and if any link is a shrug, the control is weak. Governing what an agent may do before it acts is its own discipline, and Issue 33 covers it; the operational point here is narrower. Every automated containment needs a human name behind it, recorded before the incident.

The third is the record. Requirements 3.6.1 and 3.6.2 ask for an incident-handling capability that covers detection through recovery, and for incidents to be tracked, documented and reported. A DoD report filed through DIBNet and a later assessment both need a timeline that separates what the machine observed, what it concluded, what it did, and what a person decided. AI summaries help write that timeline. They do not substitute for the source records, and an incident file built from summaries alone will not survive questioning. The broader evidence argument is in Issue 50.

What we have built, and what we have not

MacTech's own autonomous threat defense platform, AEGIS, is a fair test of these claims because it is honest about where it stops. What is built is the detection half. It observes HTTP and API traffic, reconstructs sessions and actors, describes their behavior with deterministic features a person can read, and classifies them with a baseline that abstains, with reasons, when it is not sure. Findings leave as a standard OCSF feed a SIEM can ingest, marked low or informational severity because they are descriptive assessments rather than verdicts.

The response half, the part that would block or reroute traffic under policy, is on the roadmap and not started. The hosted pilot that went live in late September has no sensor feeding it yet, and it runs on infrastructure that is not authorized for CUI. And the team's own Range testing published the number that matters most: against a stealth-scraper persona built to look human, the classifier got zero of ten sessions right, labeling six as human and four as unknown. The project records that miss as the finding, not a footnote. A detector that knows what it misses is one you can safely connect to a response playbook; one that does not know should never be allowed to disable anything.

That is the position for a small enclave this year. Let the machine read everything, write the first draft of the story, and take the cheap, reversible step on accounts and workstations a person has already signed off. Keep the server, the reporting decision and the evidence in human hands, and if you want help drawing that line for your own enclave, start with a readiness review. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine

new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF

mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.

Published from Git, reviewed like code.